API SPECIFICATION / 01

# ChemBridge API 명세서

정지우 - Java 인증 연동·RAG API / 2026-10-23 / v1.3

화학안전·중대재해 법령 다국어 안내 서비스의 현재 API 계약, 보류·오류 정책과 검증 결과를 정리한다. 공개 요청·응답의 이름은 rag/schema.py를 따른다.

## 서비스와 인증 흐름

| 구성 | 역할·주소 |
|---|---|
| Vue | :5174. 현재 Vite 프록시·HttpOnly 쿠키로 Java/RAG 호출. RAG의 5언어 계약과 프론트 UI 지원 범위는 구분한다. |
| Java | :8080. Spring Boot/MVC, MariaDB :53301의 회원 확인 → JWT 발급. |
| FastAPI | :8001. Bearer/ACCESS_TOKEN 검증 → chain.answer(req) → 안내·출처. |
| RAG 내부 | 비상/범위 밖 사전 처리 → bge-m3 + FAISS 검색 → 구조화 답변 생성 → 주장·근거 검증. 정상 경로는 보통 LLM 2회. |

## 공개 API 목록

| 서버 | 메서드·경로 | 인증 |
|---|---|---|
| Java | POST /api/signup | 공개 |
| Java | POST /api/login | 공개 |
| Java | GET /api/auth/check | Bearer 또는 기존 쿠키 |
| Java | POST /api/logout | 공개 / 기존 세션·쿠키 삭제 |
| RAG | POST /rag-query | Bearer 또는 ACCESS_TOKEN |
| RAG | GET /health | 공개 |
| RAG | GET /raq-query-log | Bearer 또는 ACCESS_TOKEN |

## 적용 범위

루트 README·담당 문서와 현재 코드·OpenAPI를 대조했다. 문서화와 API 미들웨어만 정지우 범위에서 변경하며 검색·생성·스키마·프론트는 수정하지 않는다. 루트 plan.md는 참고하지 않았다.

출력 예시는 형식 설명용이며 실제 법률 판단이나 현장 작업 승인이 아니다.

API SPECIFICATION / 02

# 회원가입 · 로그인

Java :8080 / application/x-www-form-urlencoded

## POST /api/signup

| 항목 | 계약 |
| --- | --- |
| 요청 | username, password: 필수 문자열. 앞뒤 공백 제거 후 비어 있으면 400. |
| API 성공 | Accept: application/json → 201 {"ok":true} |
| 웹 폼 성공 | JSON 응답을 요청하지 않으면 302, Location: /login |
| 오류 | 400: 필수값 누락·중복 아이디 / 500: 회원 저장 실패. 기존 오류는 text/plain. |
| 저장 | 기존 users 테이블. 비밀번호는 BCrypt cost 12 해시. SQL 파라미터 바인딩. |

```
POST http://localhost:8080/api/signup
Content-Type: application/x-www-form-urlencoded
Accept: application/json

username=sample_user&password=sample_password
```

## POST /api/login

같은 폼 필드를 받는다. 로그인 성공은 항상 200 JSON이며 API가 302로 페이지를 이동하지 않는다. redirect는 웹 화면이 사용할 이동 주소다.

```
{
  "ok": true,
  "redirect": "http://localhost:5174/",
  "accessToken": "<JWT>",
  "tokenType": "Bearer",
  "expiresIn": 3600
}
```

| 항목 | 계약 |
| --- | --- |
| 오류 | 400: 입력 누락 / 401: 로그인 정보 불일치 / 500: 인증 처리 실패. JSON {ok:false,error:...}. |
| JWT | HS256, iss=simple-auth-server, sub=회원 ID, username, iat, exp. 1시간 만료. |
| 쿠키 | SESSION_ID·ACCESS_TOKEN: HttpOnly. APP_AUTH: JS 읽기 가능. Path=/, SameSite=Lax. |

Java /api/ 응답에 Cache-Control: no-store 적용. JWT_SECRET은 서버 공통 비밀키이며 accessToken과 다르다. 비밀값은 문서에 넣지 않는다.

API SPECIFICATION / 03

# 인증 확인 · 로그아웃

Bearer 헤더 우선, 기존 세션·쿠키 호환

## GET /api/auth/check

Authorization이 있으면 해당 Bearer만 검증한다. 잘못된 Bearer를 유효 세션·쿠키로 우회하지 않는다. 헤더가 없으면 SESSION_ID 세션, ACCESS_TOKEN JWT를 확인한다.

```
GET http://localhost:8080/api/auth/check
Authorization: Bearer <JWT>

{
  "ok": true,
  "via": "bearer",
  "username": "sample_user",
  "sub": "42"
}
```

| 경우 | 응답 |
| --- | --- |
| Bearer 성공 | 200: via=bearer, username, sub |
| 세션 성공 | 200: via=session, username. sub는 없음. |
| JWT 쿠키 성공 | 200: via=jwt, username, sub |
| 실패 | 401 {"ok":false,"reason":"UNAUTHORIZED"}, WWW-Authenticate: Bearer |

## POST /api/logout

요청 본문은 없다. SESSION_ID 서버 세션을 지우고 SESSION_ID·ACCESS_TOKEN·APP_AUTH를 Path=/, Max-Age=0으로 만료시킨다.

| 경우 | 응답·처리 |
| --- | --- |
| JSON 요청 | Accept: application/json → 200 {"ok":true} |
| 웹 폼 | 302, Location: /login |
| 복사한 JWT | 즉시 폐기 목록은 없다. exp 만료 또는 키 변경 전까지 검증 가능. |
| Swagger·클라이언트 | 보관한 Bearer도 삭제한다. Swagger는 Authorize > Logout. |

세션은 서버 메모리이며 재시작 시 사라진다. 만료·재인증 UI는 프론트 담당과 공동 검증한다. 토큰을 URL에 넣지 않는다.

API SPECIFICATION / 04

# RAG 질문 요청

POST http://localhost:8001/rag-query / application/json

Content-Type: application/json
Authorization: Bearer <JWT>

Bearer가 없으면 기존 ACCESS_TOKEN 쿠키를 지원한다. 쿠키 사용 시 localhost 호스트를 맞춘다. 아래 language 값은 현재 공통 스키마에서 가져온다.

| 필드 | 형식·필수 | 제약·의미 |
|---|---|---|
| question | string / 필수 | 2~500자 |
| topic | string / 필수 | chemical_safety / serious_accident_law |
| product_id | string 또는 null / 선택 | 기본 null. 제품별 MSDS 검색 범위. 법령은 null. |
| equipment_id | string 또는 null / 선택 | 기본 null. 가상 장비의 제품 범위. 제품 ID가 있으면 제품이 우선. |
| language | string / 선택 | ko · zh · vi · en · km. 기본 ko. |

## 법령 질문 - 실제 출처 반환을 확인한 예시

```
{
  "question": "중대재해처벌법 제2조에서 정한 중대산업재해의 정의는 무엇인가요?",
  "topic": "serious_accident_law",
  "language": "ko"
}
```

## 제품·장비 요청 형식 예시

```
{
  "question": "선택한 제품의 보호구 정보는 어떤 문서에서 확인하나요?",
  "topic": "chemical_safety",
  "product_id": "sigma-339741",
  "equipment_id": "DEMO-WET-01",
  "language": "ko"
}
```

제품 ID만 지정해도 정상 답변이 보장되는 것은 아니다. 제품 식별·농도·개정일·질문별 근거가 충분해야 한다. 장비 목록은 가상 시연 데이터다. 현재 프론트 UI는 3언어·제품 미선택 흐름이므로 API의 전체 기능 지원과 구분한다.

API SPECIFICATION / 05

# RAG 응답 · 출처 · 보류

HTTP 200은 근거 답변 완료를 보장하지 않는다.

| 필드 | 형식 | 의미 |
|---|---|---|
| answer | string | 근거 안내, 비상 안내 또는 판단 보류 문구 |
| sources | Source[] | 생성·검증을 통과해 선택된 원문 출처. 보류이면 빈 배열일 수 있음. |
| needs_review | boolean | 담당자 추가 확인 필요 |
| handoff | boolean | 담당자 연결/판단 보류 필요. 실제 연락 완료를 의미하지 않음. |
| latency_ms | integer | 체인 처리 시간(ms). API HTTP 전체 지연과 측정 구간이 다름. |

## Source 객체

| 필드 | 형식·기본값 | 의미 |
|---|---|---|
| doc_id | string / 필수 | 예: L2. 최신 생성기는 빈 doc_id의 근거를 보류함. |
| section | string / 필수 | 조문·문서 내 위치 |
| title | string / 필수 | 원문 문서명 |
| url | string / 기본 빈 문자열 | 원문 링크. 기본 Source 모델과 생성기의 근거 검증 규칙은 구분함. |

## 근거 부족 응답 예시

```
{
  "answer": "제공된 자료에서 질문에 답할 충분한 근거를 확인하지 못했습니다. 담당자에게 확인하세요.",
  "sources": [],
  "needs_review": true,
  "handoff": true,
  "latency_ms": 5211
}
```

검색 결과가 있어도 질문에 충분하지 않으면 생성 LLM이 supported=false로 판단해 출처 없이 보류할 수 있다. 검색된 모든 청크를 무조건 sources에 넣지 않는다.

자료 없음·빈 메타데이터·제품 미확인·인용/번역 검증 실패·검증 서비스 불가 등의 보류를 HTTP 장애와 구분한다. 비상/범위 밖 사전 응답과 실제 검색 0건은 LLM 전에 종료될 수 있다.

검토 플래그가 true여도 검증된 출처가 함께 반환되는 경우가 있다. 프론트는 답변·출처·두 플래그를 함께 표시해야 한다.

API SPECIFICATION / 06

# 상태 확인 · 오류 계약

현재 구현의 동작과 공동 계약 대기 항목을 구분한다.

## GET /health - 공개

```
{
  "ready": true,
  "indexes": {
    "serious_accident_law": true,
    "chemical_safety": true
  }
}
```

한 topic 이상 로드되면 200, 전부 미준비이면 503이다. ready=true는 모든 topic 준비를 뜻하지 않는다. 모델·인덱스 변경 후 서버 재시작이 필요하다.

## RAG 오류

| 코드 | 조건 | 본문 |
|---|---|---|
| 401 | 토큰 없음·위조·만료·필수 claim 오류 | {"detail":"토큰이 없거나 만료되었거나 올바르지 않습니다."} |
| 422 | 길이·topic·language·선택 필드 타입·JSON 오류 | {"detail":[...]}: loc, msg, type 등 |
| 503 | JWT 키 미설정 | {"detail":"인증 서비스를 사용할 수 없습니다. 잠시 후 다시 시도해 주세요."} |
| 503 | 체인에서 예외로 전달한 검색/생성 실패 | {"detail":"잠시 후 다시 시도해 주세요."} |
| 500 | 의존성·응답 검증 등 예상 밖 오류 | {"detail":"요청 처리 중 오류가 발생했습니다."} |

## 현재 합의가 필요한 동작

특정 topic 인덱스 부재는 현재 빈 검색 결과와 같이 200 + handoff일 수 있다. 준비 장애 503 구분은 검색·체인 담당과 공동 계약 대기다. API가 별도로 검색을 호출해 우회하지 않는다.

생성 모델 timeout/error는 503으로 전달된다. 검증 모델 불가/timeout은 현재 200 보류일 수 있으며, 이를 같은 HTTP 장애로 바꿀지는 별도 합의가 필요하다.

## Java·공통 HTTP 오류

Java 가입 오류는 text/plain, 로그인 오류는 JSON {ok:false,error:...}, 인증 확인 실패는 {ok:false,reason:UNAUTHORIZED}다. 404·405·415와 연결 실패도 클라이언트에서 처리한다.

401: 재로그인 / 422: 입력 확인 / 503: 안내 후 재시도. 200 보류를 정상 근거 답변으로 표시하지 않는다. 내부 예외·SQL·비밀키는 본문에 노출하지 않는다.

API SPECIFICATION / 07

# 미들웨어 · CORS

기존 요청 로그와 HTTP 응답 정책

## 요청별 로그

path=/rag-query status=200 latency_ms=5222.64

| 항목 | 정책 |
| --- | --- |
| 기록 | 등록된 경로, 최종 상태코드, HTTP 처리 시간(ms) |
| 제외 | 질문/답변 본문, 비밀번호, JWT·쿠키, 쿼리 문자열, 예외 원문 |
| 미등록 경로 | RAG /unmatched, Java /<unmatched>로 정규화 |
| RAG | ASGI RequestLogMiddleware. uvicorn.access 기본 로그 비활성화. 일반화한 500도 CORS 유지. |
| Java | RequestPolicyFilter. CORS·/api/ no-store·예외 일반화·경로/상태/지연 기록. |

## 허용 Origin

| 서버 | Origin |
| --- | --- |
| RAG | http://localhost:5174 / http://127.0.0.1:5174 |
| Java | localhost / 127.0.0.1의 :5174, :8080, :8001<br>추가로 http://localhost:8008 |

| 정책 | Java | RAG |
| --- | --- | --- |
| 자격 증명 | true | true |
| 메서드 | GET, POST, OPTIONS | GET, POST, OPTIONS |
| 명시 허용 헤더 | Content-Type, Authorization, Accept | Authorization, Content-Type |
| 정상 preflight | 204 | 200 |
| 미허용 Origin preflight | 403 | 400, 허용 Origin 헤더 없음 |

CORS는 브라우저 정책이며 JWT 인증을 대체하지 않는다. localhost와 127.0.0.1은 쿠키 호스트가 다르다. Bearer만 사용하면 해당 쿠키 차이에 의존하지 않는다.

API SPECIFICATION / 08

# 검증 결과 · 확인된 한계

단위 검증과 실제 모델 진단은 별도 근거다.

| 구분 | 결과·범위 |
| --- | --- |
| 전체 오프라인 RAG | 562 통과 / 12 건너뜀 / 실패 0. 실제 모델용 테스트는 별도 활성화. |
| API 회귀 | 로그 조회의 인증·필터·보관·개인정보 보호, 정상 출처 전달, 빈/누락 doc_id의 생성 전 보류, 5언어 인증·검증·오류·CORS·로그. |
| 실제 모델 진단 | 같은 최신 코드·재적재 인덱스에서 FAISS 검색 → 생성·검증 LLM 실행. API 전송과 의미상 정확도 판정은 구분. |
| 로컬 데이터 | 법령 262 + 지침/MSDS 559 = 821청크. 필수 출처 메타데이터 빈 값 0건. bge-m3, 1024차원. |

## 같은 주제라도 검색 근거가 달라지는 실제 사례

| 요청 | 관측 결과 |
| --- | --- |
| 중대재해법의 기준은? | 제6·15·10·1·7조 검색. 제2조 누락 → 생성 supported=false → 200, sources=[]·handoff=true. |
| 중대재해처벌법 제2조의 중대산업재해 정의 | 제2조 검색 1위 → 실제 생성·검증 호출 → 200, doc_id=L2 출처 1건. 현행성/조건 검토 플래그 유지. |
| 제품 ID 없는 황산 보호구 질문 | 제품 확인 근거가 충족되지 않아 product_unverified로 보류. doc_id 정상만으로 충분하지 않음. |

## 범위·후속 담당

검색·질문 정규화는 김규빈, 적재·메타데이터는 윤서진, 생성·근거 검증은 박진근, 프론트는 강지훈 담당이다. API는 체인 결과를 그대로 반환하며 근거를 임의로 만들지 않는다.

준비 장애 503 구분, 제품/장비 선택 연결, 전체 timeout 정책과 실제 LLM usage·비용 집계는 각 담당과 공동 계약이 필요하다. 이번 지연 집계는 HTTP 시간만 다룬다.

이전 문서의 빈 doc_id·미준비 MSDS 상태와 오래된 테스트 수치를 현재 결과로 대체했다. 부하·배포·법률 정확도 전체 평가를 완료했다는 의미는 아니다.

API SPECIFICATION / 09

# Swagger 사용 · 검증 근거

서버를 재시작하면 최신 코드의 OpenAPI를 읽는다.

## 시연 순서

1. ./dev.sh로 백엔드를 실행하고 http://localhost:8001/docs에 접속한다.
2. Java 인증 그룹의 signup/login으로 토큰을 받는다.
3. accessToken 값만 Authorize에 붙여 넣는다.
4. RAG 법령 예시를 실행하고 answer·sources·검토 플래그를 함께 본다.
5. /api/logout 후 Authorize > Logout으로 복사한 토큰을 지운다.

Java 항목은 :8080을 직접 호출한다. Python의 /api/login은 실제 프록시 경로가 아니므로 404다. Swagger가 쿠키로 성공해도 복사한 curl에 쿠키가 빠질 수 있다.

## 요청 예시

```
curl -X POST http://localhost:8001/rag-query \
  -H 'Content-Type: application/json' \
  -H 'Authorization: Bearer <JWT>' \
  -d '{
  "question": "중대재해처벌법 제2조에서 정한 중대산업재해의 정의는 무엇인가요?",
  "topic": "serious_accident_law",
  "language": "ko"
}'
```

## 검증 명령

```
# rag-service 폴더
../.venv/bin/python -m pytest -q tests

# auth-server 폴더 (Java 변경 검증 시)
./gradlew :app:test --no-configuration-cache
```

## 저장소 근거

| 구분 | 경로 |
| --- | --- |
| 기준 | README.md / docs/tasks/정지우_API.md |
| 공통 계약 | rag-service/rag/schema.py |
| API·인증·미들웨어 | rag-service/app/main.py / app/auth.py |
| 생성·검색 흐름 | rag-service/rag/chain.py, retriever.py, generator.py |
| 검증 산출물 | output/pdf/chembridge-openapi.json<br>output/pdf/chembridge-api-verification.json |

API SPECIFICATION / 10

# HTTP 지연 집계

API 미들웨어만 계측. LLM 토큰 수·비용은 포함하지 않는다.

기존 요청별 latency_ms 로그를 유지하면서 요청 수·오류·최소/평균/최대 HTTP 지연을 누적한다. 경로·메서드·상태코드별 집계로 /health·문서 조회와 실제 RAG 질의를 구분한다.

| 항목 | 정책 |
| --- | --- |
| 측정 구간 | ASGI HTTP 요청 수신부터 마지막 응답 body 전송 완료 또는 실패까지. 서버 시작의 모델 로딩 시간·클라이언트 전체 왕복은 제외. |
| 집계 | 요청 수, 완료/미완료 응답 수, 4xx·5xx 수, 실패율, 지연 합계·최소·평균·최대, 상태코드 분포. |
| 보류 응답 | 200 + handoff는 정상 HTTP 응답이다. 이 통계는 답변 정확도·업무 성공률이 아니다. |
| 경로·메서드 | 등록된 경로와 알려진 HTTP 메서드만 사용. 미등록 경로는 /unmatched, 알 수 없는 메서드는 OTHER로 묶음. |
| 동시 요청 | Lock으로 누적·스냅샷을 보호하고 JSON은 같은 폴더의 임시 파일에서 원자 교체. |
| 수명·파일 | 프로세스 시작 이후 누적, 재시작 초기화. logs/rag-latency-<PID>.json. 다중 worker는 PID별 파일을 구분하며 전체 합계로 단정하지 않음. |
| 개인정보 | 원문·사용자 ID·토큰·쿠키·쿼리·예외 내용을 저장하지 않는다. 파일 기록 실패로 API 응답을 실패시키지 않음. |

## 운영 확인

```
path=/rag-query status=200 latency_ms=5222.64
latency_summary path=/rag-query method=POST requests=3 ...

# 서버 PID에 해당하는 파일 조회
python3 -m json.tool logs/rag-latency-12345.json
# 12345는 실제 RAG 서버 PID로 교체
```

latency_ms 응답 필드는 chain 처리 시간이고 이 집계는 HTTP 전체 시간이다. 클라이언트 입력 오류·인증 실패도 해당 상태코드에 포함된다. 파일은 로컬 운영 산출물이다. 로그인한 사용자는 다음 페이지의 조회 API로 메모리 통계와 최근 기록을 확인한다.

API SPECIFICATION / 11

# 요청 로그 조회 API

GET http://localhost:8001/raq-query-log / 인증 필요

기존 Java 로그인에서 발급받은 Bearer 토큰으로 호출한다. ACCESS_TOKEN 쿠키도 호환한다. 로그인한 사용자가 보는 서비스 공통 HTTP 통계이며 사용자별 대화 이력 API가 아니다.

## 조회 매개변수

| 이름 | 계약 |
| --- | --- |
| limit | 기본 100, 1~1000. 반환할 최근 요청 수. |
| path | 선택. /rag-query 등 등록된 경로 또는 /unmatched. 생략하면 전체 경로. |
| status | 선택. HTTP 상태코드 100~599. 예: 503. |

## 응답 구성

| 필드 | 의미 |
| --- | --- |
| overall | 전체 요청 수·완료/미완료·4xx/5xx·오류율·최소/평균/최대 지연. |
| routes | 경로+메서드별 누적과 by_status별 누적. 조회 필터와 무관한 전체 누적. |
| logs | 최신순 요청 기록. sequence, recorded_at(UTC), path, method, status, latency_ms, completed, level, outcome. |
| retention / filters | 최대 보관 1000건, 현재 보관 수, 필터에 맞는 보관 수, 적용한 필터. |
| scope / pid / 시각 | 현재 프로세스의 시작 이후 누적. worker 구분과 재시작 여부 확인. |

## Swagger와 curl

서비스 상태 > GET /raq-query-log > Try it out. 먼저 Authorize에 토큰을 넣고 Execute한다. path=/rag-query, status=503으로 실패 요청만 조회할 수 있다.

```
curl 'http://localhost:8001/raq-query-log?limit=20&path=/rag-query' \
  -H 'Authorization: Bearer <JWT>'
```

## 보관·오류·제외 범위

메모리에 최신 1000건만 보관하고 재시작 시 초기화한다. 기존 로그 파일의 과거 기록을 읽거나 다른 worker의 기록을 합치지 않는다. GET 조회는 통계와 최근 목록에서 제외하며 응답에 Cache-Control: no-store를 적용한다.

401: 인증 없음·만료·위조 / 422: 조회 조건 오류 / 503: 인증 설정 미준비. 질문·답변·사용자 ID·토큰·쿠키·쿼리·원시 예외·서버 로그 파일 원문은 반환하지 않는다. LLM 토큰·비용과 호출별 추적 정보는 포함하지 않는다.